

SECTION 21 CYBER SECURITY

1 General

1.1 Objective

The additional class notation **Cyber secure** provides a structured and flexible framework for design and implementation of barriers to identify, protect, detect, respond, and recover from cyber security incidents.

1.2 Scope

1.2.1 General

These rules describe requirements to the additional class notation **Cyber secure**, including its qualifiers **Essential**, **Advanced** and **+**.

Class notation **Cyber secure** covers the three main pillars: people, process and technology as illustrated in Figure 1, by addressing the vessel's technical design and its cyber security management system (CSMS).

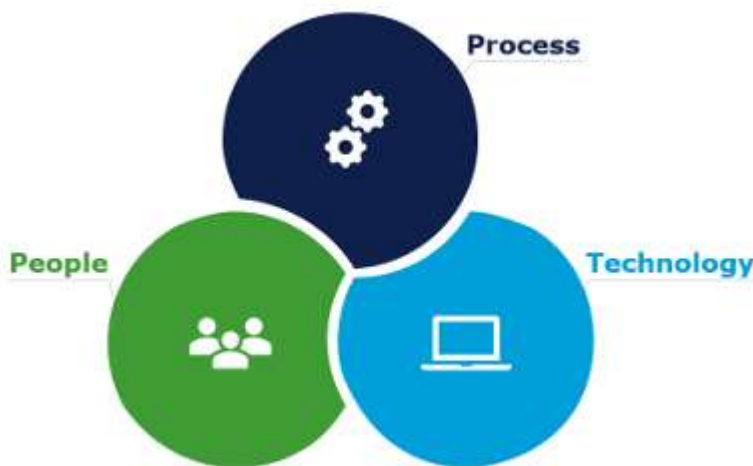


Figure 1 People, process and technology

1.2.2 Relevance to IMO and IACS

Class notation **Cyber secure** is aligned with IMO resolution MSC.428(98) and MSC-FAL.1/Circ.3.

Class notation **Cyber secure(Essential)** is aligned with IACS UR E26 and UR E27.

Class notation **Cyber secure(Advanced)** exceeds requirements from IMO and IACS.

1.2.3 Use of standards

The technical security requirements in [4] shall be understood as summary of the complete text in the referenced standard IEC 62443-3-3. Hence, unless amendments are specified (see [4.1.3]), it is mandatory to follow IEC 62443-3-3 when applying these rules.

For the application of IEC 61162-460 or other equivalent standards, see [4.1.4].

1.2.4 Type approval

Security capabilities that have been type approved in accordance with these rules (see also DNV-CP-0231) are subject to limited case-by-case verification as specified in [1.8].

1.3 Application

These rules may be applied to any ship or offshore unit where one or more vessel functions are controlled by computer based systems (CBS). For readability, the term 'computer based system' is generally replaced with 'system'. The rules may also be applied for IT-systems if selected as part of system under consideration by qualifier +, see [1.4.5].

1.4 Class notation

1.4.1 General

Vessels constructed and tested in accordance with the requirements in these rules may be assigned the class notation **Cyber secure**, with qualifiers as outlined in Table 1.

Table 1 Class notation for cyber security

Class notation	Qualifier	Purpose	Application
Cyber secure Mandatory: yes Design requirements: Sec.21 In-operation requirements: Pt.8 Ch.2 Sec.2 Retention requirements: Pt.7 Ch.4 Sec.5 [2] and Pt.7 Ch.5 Sec.2 [2]	<None>	Establish barriers to identify, protect, detect, respond, and recover from cyber security incidents.	Voluntary class notation. Initial level of cyber security based on IMO resolution MSC.428(98) and MSC-FAL.1/Circ.3. See [1.4.2] .
	Essential		Mandatory class notation for vessels contracted on or after July 1 st 2024 for the following: — passenger ships engaged in international voyages — passenger high speed craft in international voyages — cargo ships of 500 GT and upwards engaged in international voyages — high speed craft of 500 GT and upwards engaged in international voyages — mobile offshore drilling units of 500 GT and upwards — self-propelled mobile offshore units engaged in construction (e.g. wind turbine installation maintenance and repair, crane units, drilling tenders, accommodation). See [1.4.3] .
	Advanced		Voluntary class notation. Advanced level of cyber security for the vessel's essential systems. See [1.4.4] .
	+		Voluntary class notation. Selected level of cyber security for specified system(s). See [1.4.5] .

Guidance note:

The different qualifiers for **Cyber secure** are intended to provide different levels of risk reduction and flexibility of systems in scope, see Figure 2.

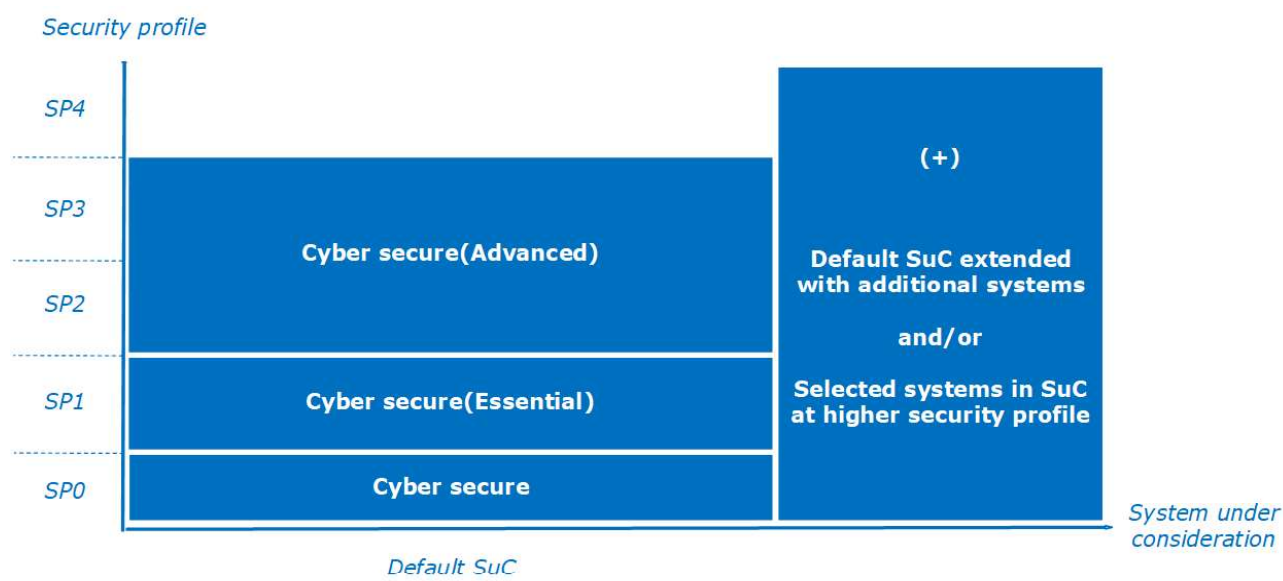


Figure 2 Cyber security risk reduction using Cyber secure

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

1.4.2 Cyber secure

For class notation **Cyber secure** the system under consideration (SuC) defined in [2] shall comply with requirements for security profile 0 (SP0).

1.4.3 Cyber secure(Essential)

For class notation **Cyber secure(Essential)** the system under consideration (SuC) defined in [2] shall comply with requirements for security profile 1 (SP1).

1.4.4 Cyber secure(Advanced)

For class notation **Cyber secure(Advanced)** the system under consideration (SuC) defined in [2] shall comply with requirements for security profile 3 (SP3).

1.4.5 Notation qualifier +

The notation qualifier **+** intends to offer flexibility with respect to risk reduction level (security profile) and SuC. The qualifier may be used in combination with **Cyber secure**, **Cyber secure(Essential)** and **Cyber secure(Advanced)**, and it may represent two different concepts as follows:

- 1) If one or more systems shall be added to the default SuC, the qualifier **+** is added to the class notation.
- 2) If one or more systems in the SuC shall comply with a higher security profile, the qualifier **+** is added to the class notation.

In either case, the vessel is assigned class notation **Cyber secure(+)**, **Cyber secure(Essential, +)** or **Cyber secure(Advanced, +)**. Information about SuC and security profile for the notation qualifier **+** will be given in the appendix to the class certificate.

Guidance note:

For the notation qualifier +, also IT systems may be added as part of the SuC, however, this is not the primary focus of these rules. See also [DNV-CG-0325](#).

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

1.5 References

1.5.1 DNV references

Relevant DNV service documents are listed in [Table 2](#) .

Table 2 DNV references

<i>Document code</i>	<i>Title</i>
Pt.4 Ch.9	Control and monitoring systems
Pt.7 Ch.1	Survey requirements for fleet in service
Pt.8 Ch.2 Sec.2	Cyber security management system - CSMS
DNV-CG-0325	Cyber security
DNV-CG-0550	Maritime services - terms and systematics
DNV-CP-0231	Cyber security capabilities of control system components
DNV-OS-D202	Automation, safety and telecommunication systems
DNV-RP-0496	Cyber security resilience management for ships and mobile offshore units in operation
DNV-RP-G108	Cyber security in the oil and gas industry based on IEC 62443

1.5.2 Other references

Relevant external standards are listed in [Table 3](#) .

Table 3 Other references

<i>Document code</i>	<i>Title</i>
ISO 27001	Information technology - Security techniques - Information security management systems - Requirements
ISO 27002	Information technology - Security techniques - Code of practice for information security controls
IEC 62443-1-1	Industrial communication networks - Network and system security Part 1-1: Terminology, concepts and models
IEC 62443-2-1	Industrial communication networks - Network and system security Part 2-1: Establishing an industrial automation and control system security program
IEC 62443-2-2	Security for industrial automation and control systems - Implementation Guidance for and IACS Security Management System
IEC 62443-2-3	Security for industrial automation and control systems - Part 2-3: Patch management in the IACS environment
IEC 62443-2-4	Security for industrial automation and control systems - Part 2-4: Security program requirements for IACS service providers

<i>Document code</i>	<i>Title</i>
IEC 62443-3-3	Industrial communication networks - Network and system security Part 3-3: System security requirements and security levels
NIST 800-46	Guide to Enterprise Telework Remote Access, and Bring Your Own Device (BYOD) Security
NIST 800-82	Guide to Industrial Control Systems (ICS) Security
IACS UR E26	Cyber resilience of ships
IACS UR E27	Cyber resilience of on-board systems and equipment
IEC 62443-3-1	Industrial communication networks - Network and system security - Part 3-1: Security technologies for industrial automation and control systems
IEC 62443-3-2	Security for industrial automation and control systems Security Risk Assessment, System Partitioning and Security Levels
IEC 62443-4-2	Industrial communication networks - Network and system security Part 4-2: Technical security requirements for IACS components
IEC 61162-460	Maritime navigation and radiocommunication equipment and systems - Digital interfaces Part 460: Multipletalkers and multiplelisteners - Ethernet interconnection - Safety and security
IMO 428(98)	Maritime Cyber Risk Management in Safety Management Systems
MSC-FAL.1/Circ.3	Guideline on Maritime Cyber risk Management
NA	The Guidelines on Cyber Security Onboard Ships, produced and supported by BIMCO, CLIA, ICS, INTERCARGO, INTERMANAGER, INTERTANKO, IUMI, OCIMF and WORLD SHIPPING COUNCIL

1.6 Definitions and abbreviations

Definitions are given in [Table 4](#).

Table 4 Definition of terms

<i>Term</i>	<i>Definition</i>
authentication	process of validating identity
authorization	right or permission that is granted to a system entity to access a system resource. Authorization is dependent on authentication
availability	ability of an item to be in a state to perform a required function under given conditions at a given instant or over a given time interval, if the required external resources are provided
asset operator	responsible part operating the vessel
asset owner	responsible part owning the vessel
compensating countermeasure	countermeasure implemented in lieu of an inherent security capability that is not provided by the system or component
computer-based system	programmable electronic device, or interoperable set of programmable electronic devices, organized to achieve one or more specified purposes such as collection, processing, maintenance, use, sharing, dissemination, or disposition of information
conduit	physical and/or logical grouping of communication channels, connecting a security zone to another zone or to an untrusted network

<i>Term</i>	<i>Definition</i>
cryptographic algorithm	well-defined computational procedure that takes variable inputs, including a cryptographic key (if applicable), and produces an output NIST defines three main types of cryptographic algorithms: cryptographic hash functions, symmetric-key algorithms and asymmetric-key algorithms. See NIST SP 800-175B Rev.1.
cyber attack	actions required to preclude unauthorized use of, denial service to, modifications to, disclosure of or destruction of critical systems or informational assets
cyber security barrier	any measure taken that acts against some undesirable force or intention in order to maintain a desired state
cyber threat	circumstance or event that has, or indicates, the potential to exploit vulnerabilities and to adversely impact (create adverse consequences for) organizational operations, organizational assets (including information and information systems), individuals, other organizations or society
firewall	inter-network connection device that restricts data communication traffic between two connected networks
hardening	process of securing a system by reducing its vulnerability surface
integrator	party responsible for acquiring, installing, and integrating systems and components in the SuC
island mode	self-contained operation and no connections to other resources
logical segmentation	segregation by 'virtual' means (e.g. VLAN) between two or more systems utilizing same physical resources
information technology	application of computers to store, study, retrieve, transmit and manipulate data, or information, often in the context of a business or other enterprise
malware	malicious software that may be harmful and/ or intrusive to computer based systems. Such software includes e.g. worms, wiperware and ransomware
manufacturer	party supplying computer-based systems or components to the vessel
operational technology	hardware and software dedicated to detecting or causing changes in physical processes through direct monitoring and/or control of physical devices such as valves, pumps, etc.
penetration	successful unauthorized access to a protected system resource
penetration testing	authorized simulated attack on a computer system, performed to evaluate the security of the system
physical segmentation	physical division between resources
remote access	access to a system in a security zone from or via an untrusted network
remote control	control from a location on the vessel not in the vicinity of the actual equipment e.g. bridge, central control room
restricted area	physical location on board to which human access is controlled, i.e. only authorized personnel can enter the location. Such areas are normally equipped with locking mechanisms and/or continuously manned. See also Sec.4 [2.15] in DNV-CG-0325
sheep dipping station	standalone computer used to clean removable devices for malware before connecting to a system
system under consideration	all computer-based systems in the scope of class notation Cyber secure
trusted network	zones or conduits included in the SuC that meet the requirements of these rules

<i>Term</i>	<i>Definition</i>
untrusted network	zones, conduits, systems, or components not part of the SuC
vulnerability	flaw or weakness in a system's design, implementation or operation and management that may be exploited to violate the system's integrity or security policy
whitelisting	restricted use of resource unless especially permitted
zone	grouping of logical or physical assets that share common security requirements

1.7 Abbreviations

Abbreviations are given in [Table 5](#).

Table 5 Abbreviations

<i>Abbreviation</i>	<i>Description</i>
AES	advanced encryption standard
AIS	automatic identification system
AP	approval
BNWAS	bridge navigational watch system & alarm system
BOP	blowout preventer
CAT	customer acceptance test
CBS	computer based system
CCR	central control room
CPP	controllable pitch propeller
CSMS	cyber security management system
CSRS	cyber security requirements specification
DMZ	demilitarised zones
DoS	denial of service
ECDIS	electronic chart display & information system
ECR	engine control room
EPIRB	emergency position indicating radio beacon
ESD	emergency shutdown system
FAT	factory acceptance test
FI	for information
FR	foundational requirement
GNSS	global navigation satellite system
GPS	global positioning system
HAT	HAT

<i>Abbreviation</i>	<i>Description</i>
IDS	intrusion detection system
IPS	intrusion prevention system
IPSec	internet protocol secure
IT	information technology
MC	mechanical completion
MPD	manage pressure drilling
OT	operational technology
PKI	public key infrastructure
PSD	process shut down
RAS	remote access server
RPM	revolutions per minute
RSA	encryption algorithm made by Ron Rivest, Adi Shamir and Leonard Adleman
SAT	systems acceptance test
SIEM	security information and event management
SIS	safety instrumented system
SL-T	security level target
SP	security profile
SuC	system under consideration
USB	universal serial bus
VLAN	virtual local area network
VPN	virtual private network

1.8 Procedural requirements

1.8.1 Documentation of vessel

The documentation in [Table 6](#) shall cover all systems and components in the SuC and shall be submitted to the Society by the integrator.

Table 6 Cyber security documentation of vessel

Object	Documentation type	Additional Description	Info
SuC	F071 - Inventory list	A complete vessel asset inventory, incorporating the asset inventories of all systems in the SuC. Any equipment in the SuC delivered by the systems integrator shall also be included in the vessel asset inventory. The vessel asset inventory shall specify the security zone to which each system has been allocated.	AP
	F031 - Zone and conduit diagram		AP
	F011 - Cyber security design description		AP
	F251 - Test procedure		AP
See requirements for document content in DNV-CG-0550 .			

Guidance note:

Since definition of the SuC and the conduits to untrusted networks will form the basis for the design, integration, testing, and documentation of class notation **Cyber secure**, it is recommended that the integrator submits first version of F031 and F011 (including risk assessment as per [\[2.2\]](#) early in the project.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

1.8.2 Documentation of systems

For systems in the SuC required to meet SP1 or higher, documentation package F200 in [Table 7](#) shall be submitted to the Society by the manufacturer or supplier of the system.

For systems required to meet SP0, the information of F200 shall be incorporated into the relevant documents in [Table 6](#) and submitted to the Society by the integrator.

For systems where devices or subsystems from multiple suppliers are integrated in a system (e.g., integrated navigation system), the integrator or an appointed organisation responsible for system integration shall submit documentation package F200.

Table 7 Cyber security documentation of systems

Object	Documentation type	Additional description	Info
System in SuC	F200 - Cyber security documentation for systems	For systems with security capabilities type approved by DNV, F200 shall include the following documents: — F030 - System topology — F071 - Inventory list — F262 - Test report or declaration of hardening and security configuration.	AP
		For systems without type approved security capabilities, F200 shall include the following documents: — F030 - System topology — F071 - Inventory list — F021 - Description of security capabilities — F252 - Procedure for test of security capabilities — F259 - Description of secure development lifecycle processes — F141 - Guidelines for hardening and configuration of security capabilities — F142 - Information supporting incident response and recovery — F253 - Procedure for verification of security functions on board — I320 - Software change handling procedure.	AP
See requirements for document content in DNV-CG-0550 .			

1.8.3 Required compliance documentation

For systems in the SuC required to meet SP1 or higher, the security functions are subject to product certification for each delivery. Such systems shall be delivered by the manufacturer with product certificate in accordance with [Table 8](#).

For systems where devices or subsystems from multiple suppliers are integrated in a system (e.g., integrated navigation system), the integrator or an appointed organization responsible for system integration shall obtain product certificate in accordance with [Table 8](#).

Table 8 Compliance documents

<i>Object</i>	<i>Compliance document type</i>	<i>Issued by</i>	<i>Compliance standard ²⁾</i>	<i>Additional description</i>
Security functions for systems in the SuC	PC ¹⁾	Society	Sec.21	See process for product certification in Pt.4 Ch.9 Sec.1 [1.4] .

Object	Compliance document type	Issued by	Compliance standard ²⁾	Additional description
1) Applies for systems required to meet SP1, SP2, SP3 or SP4. 2) Unless otherwise stated in the compliance standard of the rules.				

Guidance note:

The process for product certification consists of:

- plan approval, see [1.8.2]
- manufacturing survey, see [5.2]
- issuance of product certificate.

Systems with type approved security capabilities may be exempted from manufacturing survey. See DNV-CP-0231 for a description of the type approval scheme.

Systems that are required by other DNV rules to be delivered with product certificate should be delivered with one common PC covering all applicable requirements.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

For a definition of the compliance document types, see DNV-CG-0550 Sec.3.

2 System under consideration (SuC)

2.1 Introduction

The term 'system under consideration' (SuC) denotes all computer-based systems in the scope of a **Cyber secure** notation.

The default SuC for all **Cyber secure** notation qualifiers shall constitute the systems in [2.3.1]. Additional systems may be added to the SuC by notation qualifier + as described in [1.4.5].

2.2 Exclusion based on negligible risk

2.2.1 Exclusion of systems from the security requirements

A risk assessment shall be carried out if excluding a computer-based system from the security requirements in [4]. The objective is to determine if the system may be considered to represent negligible cyber risk. The risk assessment shall at least consider the criteria listed below:

- 1) The system shall be isolated and not have IP-network communication with other systems (including no remote access solution).
- 2) The system shall be located in area(s) to which physical access is restricted and controlled.
- 3) The system shall not have accessible physical interface ports. Unused interfaces shall be logically disabled. It shall not be possible to mount external devices to the system.
- 4) The system shall not be an integrated control system serving multiple vessel functions, see Pt.4 Ch.9 Sec.2 [1.3].

The following additional criteria should also be considered in the risk assessment:

- 1) The system should not be needed for propulsion and steering, and should not include required safety functions.
- 2) The attack surface for the CBS is minimized, having considered the system's complexity, connectivity, physical and logical access points, including wireless access points.
- 3) Known vulnerabilities, threats, attack surface, and potential impacts deriving from a cyber incident should be considered.

The above risk assessment shall be submitted by the integrator as part of document F011, see Table 6

Guidance note:

The above items are intended as an approximation to determine the likelihood of an attack for each individual system. See [DNV-RP-0496](#) for further details and guidance. See also IACS UR E26 chapter 6.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

2.2.2 Exclusion of components from a system

A risk assessment shall be carried out if excluding a component in a system from the security requirements in [\[4\]](#). The objective is to determine if the component may be considered to represent negligible cyber risk. The risk assessment shall be submitted by the manufacturer as part of document F021, see [Table 7](#).

Guidance note:

The following attack surfaces should at least be considered:

- communication with other systems or components
- physical access restriction
- physical or logical interfaces that can be used for software update, configuration, transfer of files, or other management activities.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

2.3 Default SuC

2.3.1 Mandatory functions

The systems needed to maintain operation of the vessel functions listed in [Table 9](#) shall be included in the default SuC.

Table 9 Default SuC

<i>Function</i>	<i>Examples of systems ¹⁾</i>
Propulsion	Systems needed for propulsion of the vessel. E.g. propeller pitch, engine speed, thruster, electrical motors and drives.
Steering	Systems needed for steering of the vessel. E.g. rudder, azimuth thruster, electrical motors and drives.
Watertight integrity	Systems needed to meet requirements for internal and external watertight integrity. E.g. internal watertight doors, shell doors, flooding detection.
Bilge and ballast systems, loading computer	Systems needed to meet requirements for bilge drainage, and ballasting. E.g. valves, pumps, level measurement. loading computer
Anchoring and mooring	System(s) needed to meet requirements for anchoring and mooring in Pt.3 Ch.11 Sec.1 .
Electrical power	Systems needed for generation and distribution of electrical power. E.g. main and auxiliary engine, generator, switchboard, energy storage system, power management.
Auxiliary services	Systems needed to serve required auxiliary functions. E.g. cooling, fuel, lubrication, compressed air.
Safety functions	Safety systems required by applicable rules for classification. E.g. emergency shutdown, machinery protection, boiler safety, ignition source control, cargo tank overfill protection, gas detection system.
Lighting	System needed to control main, emergency and navigation lights.

<i>Function</i>	<i>Examples of systems ¹⁾</i>
Fire safety	Fire detection and alarm system and fixed fire extinguishing system required by applicable statutory regulations or rules for classification.
Navigation	Navigational systems and equipment required by applicable statutory regulations (e.g. SOLAS, MODU Code, HSLC Code): radar, AIS, GNSS, ECDIS, gyro, heading and bearing indicator, BNWAS, echo sounder, electronic plotting, speed and distance measuring device, tracking aid, rate of turn indicator and transmitting heading device.
Internal communication	Internal communication systems required by applicable statutory regulations. E.g. public announcement, general alarm, two-way voice communication.
External communication	External communication systems required by applicable statutory regulations. E.g. Global maritime distress and safety system.
¹⁾ Systems providing local, remote or automatic control as well as required monitoring, alarm, and safety functions shall be included in the SuC. Note also requirements to conduits between security zones and untrusted networks in [3.2.2]. Integrated control systems shall be included in the default SuC.	

2.4 Additional systems

2.4.1 Industrial purpose systems

Industrial purpose systems serving other vessel functions such as exemplified in Table 10 are included in the SuC if specified by applying notation qualifier +.

Table 10 Examples of industrial purpose systems

<i>Function</i>	<i>Examples of systems</i>
Dynamic positioning (DP)	Applicable for DYNPOS and DPS notation. The following control and monitoring system(s) for dynamic positioning should be addressed: automatic main control system, automatic back-up control system, automatic alternative control system and manual independent joystick control system.
Auxiliary thruster	Control and monitoring system for thrusters not part of propulsion function.
Drilling	Applicable for DRILL notation. The following control and monitoring system(s) for drilling should be addressed: hoisting and rotating, active heave compensation, MPD and BOP.
Cargo	Control and monitoring systems for cargo.
Production	Applicable for PROD notation. The following control and monitoring system(s) for production should be addressed: PSD.

3 Common requirements

3.1 Introduction

This subsection describes the common requirements that apply for class notation **Cyber secure** regardless of selected qualifier.

3.2 Security zones and conduits

3.2.1 Zones

When the systems in the SuC have been identified, the integrator shall group the systems into security zones. The security zones shall constitute different network segments and shall meet requirements in [4.6.1] and [4.6.2]. All systems in a security zone shall meet the security requirements of the zone.

The security zones and conduits shall be illustrated in the zones and conduit diagram, see Table 6.

Guidance note:

Note that a high number of zones requires many or complex segmentation devices and consequently increased administrative efforts to be incorporated in the CSMS. Such complexity may have negative effects on availability and security.

There may be multiple systems and/or network segments within one zone. Systems with similar properties may be grouped into the same zone. The grouping of systems into the same zone should be based on a combined evaluation of:

- systems supporting the same or similar vessel function
- systems located in the same physical space
- systems are similar with respect to e.g. amount of data, speed of data, communication protocols
- systems are subject to the same security requirements.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

3.2.2 Conduits

Any communication channel traversing a zone boundary shall be identified (such communication channel is denoted 'conduit'). Network traffic traversing zone boundaries shall be monitored and controlled as per requirements in [4.6.3].

Physical and logical components being part of a conduit between security zones shall meet the most demanding requirements of the interconnected zones.

Conduits between security zones and untrusted networks shall meet requirements identified as applicable for 'untrusted networks' in [4].

Guidance note:

The conduits and their numbering should be reflected in network filtering rules for routers and firewalls.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

Figure 3 shows an example of zones and conduits.

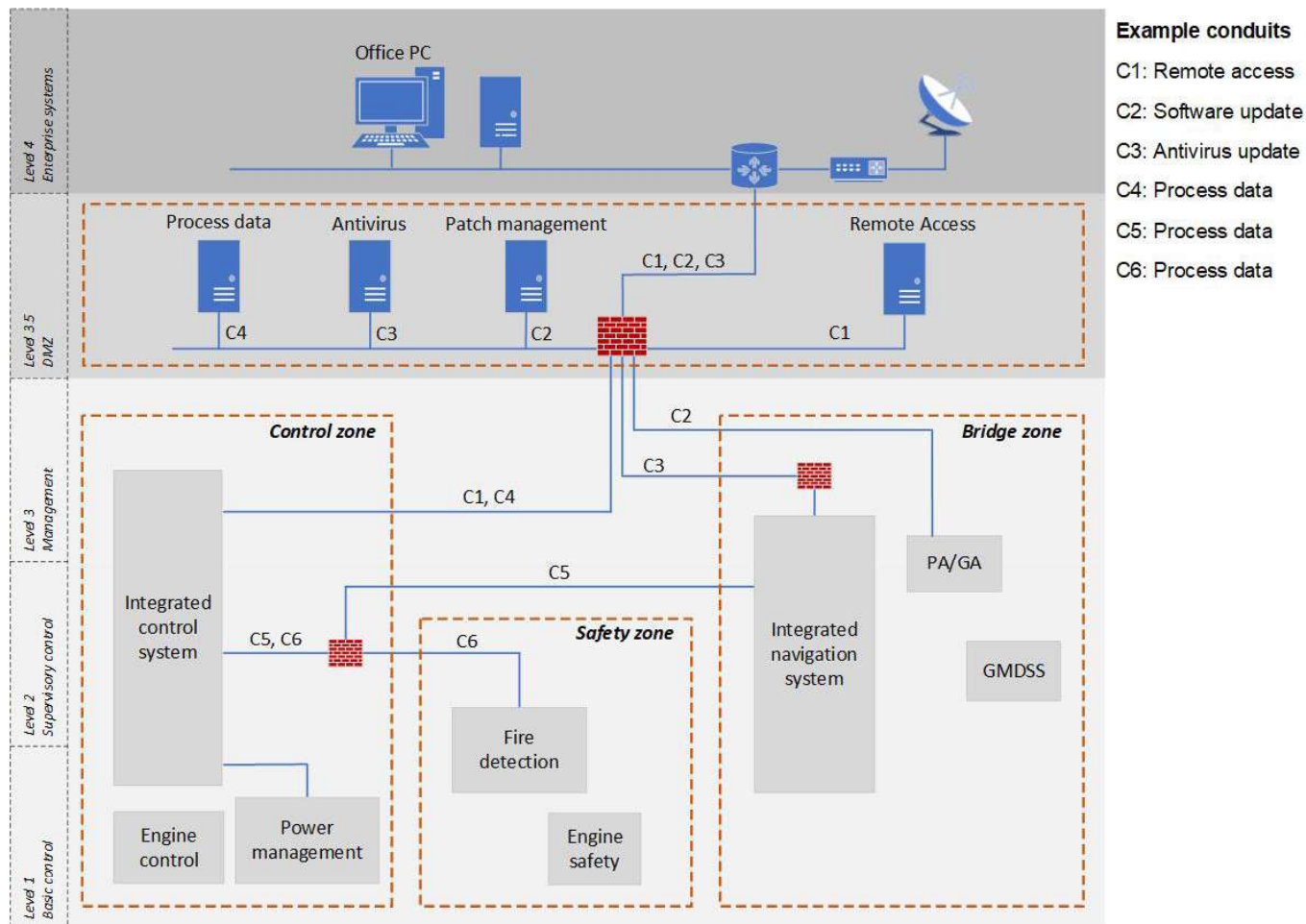


Figure 3 Example of zones and conduits

3.3 Secure product development lifecycle requirements

3.3.1 General

The manufacturer shall have established processes to manage cyber security as per the following subsections.

3.3.2 Modifications

The manufacturer shall manage modifications of the system in accordance with requirements in [Pt.4 Ch.9 Sec.1 \[1.6\]](#).

3.3.3 Secure software development lifecycle requirements

The manufacturer shall meet the requirements in [Table 11](#). Relevant documents in the manufacturer's management system shall be submitted as specified in document F259 in [Table 7](#). Adherence with these requirements are subject to audit as specified in [\[5.2.4\]](#).

Table 11 SDL requirements

<i>Requirement summary</i>	<i>Reference</i>
Control of private keys	IEC 62443-4-1 SM-8
Security update documentation	IEC 62443-4-1 SUM-2
Dependent component or operating system security update documentation	IEC 62443-4-1 SUM-3
Security update delivery	IEC 62443-4-1 SUM-4
Product defense in depth	IEC 62443-4-1 SG-1
Defense in depth measures expected in the environment	IEC 62443-4-1 SG-2
Security hardening guidelines	IEC 62443-4-1 SG-3

3.4 Compensating countermeasures

A system which cannot comply with all requirements shall be protected with other compensating countermeasures. A compensating countermeasure may be technical (e.g. isolating systems in separate zones), or procedural (e.g. routines for manual logfile inspection). The compensating countermeasures shall protect against the same threats as the original requirement and shall not introduce any additional security risks. It is not acceptable to compensate for lacking security capabilities by controls that are implemented to meet other security requirements.

Compensating countermeasures are subject to approval, see F011 in [Table 6](#).

In the context of type approval, compensating countermeasures may also be accepted if such countermeasures are part of the type approved product.

3.5 Cyber security management system

For class notation **Cyber secure**, a CSMS addressing policies, procedures, practices and behaviour of people shall be established in accordance with requirements in [Pt.8 Ch.2 Sec.2](#).

Relevant documentation from the design and construction/conversion phases shall be controlled and supplied to the organization responsible for vessel operation. This includes compensating countermeasures as described in [\[3.4\]](#). The information shall be incorporated into the CSMS.

Verification of compliance with requirements for CSMS will be done by audits on board after all technical requirements in these rules are verified and tested. See [Pt.7 Ch.4 Sec.5 \[2\]](#) for more information.

4 Technical security requirements

4.1 Introduction

4.1.1 General

Technical security requirements are specified in requirement tables and are based on the normative reference IEC 62443-3-3. The requirements are organised according to the seven foundational requirement (FR) categories of IEC 62443 as shown in [Table 12](#).

Table 12 Foundational cyber security requirements

No.	Foundational requirement ¹⁾	Objective
1	Identification and authentication	All users shall be identified and authenticated before given access to a system.
2	Use control	Enforce user's privileges and monitor these.
3	System integrity	Ensure system integrity from unauthorized manipulation.
4	Data confidentiality	Ensure confidentiality and prevent unauthorized disclosure of system communication.
5	Restricted data flow	Limit unnecessary data flow by segmenting.
6	Timely response to events	Respond to incidents and evidence of violations, and correct action when incidents are discovered.
7	Resource availability	Ensure the availability of the system in case of cyber security incident.
¹⁾ Additional guidance on foundational requirements may be found in IEC 62443-1-1.		

The requirements are classified into five security profiles (SP0 to SP4), providing an increasing level of protection against cyber threats following the concept of IEC 62443 (SL1 to SL4).

The relationship between IEC 62443 security levels (SL) and DNV security profiles (SP) is shown in [Table 13](#).

Table 13 IEC security level and DNV security profiles

DNV security profile (SP)	IEC 62443 security level (SL)
SP0. Required for Cyber secure	Selected requirements from SL1. Intended for minimum alignment with IMO MSC.428(98).
SP1. Required for Cyber secure(Essential)	SL1. Protection against casual or coincidental violation.
SP2.	SL2. Protection against intentional violation using simple means with low resources, generic skills, low motivation.
SP3. Required for Cyber secure(Advanced)	SL3. Protection against intentional violation using sophisticated means with moderate resources, IACS specific skills, moderate motivation.
SP4.	SL4. Protection against intentional violation using sophisticated means with extended resources, IACS specific skills, high motivation.

4.1.2 Security profiles adaptations

Differences between security levels (SL) in IEC 62443-3-3 and security profiles (SP) in these rules are specified in the requirement tables as follows:

- 1) SP0 is a security profile that is not based on any security level of IEC 62443-3-3. The level of risk reduction for SP0 is less than for SL1 of IEC 62443-3-3.
- 2) Requirements indicated with 'H' are 'more stringent' than IEC 62443-3-3 since these apply for an SP that is lower than the corresponding SL in IEC 62443-3-3.
- 3) Requirements indicated with 'L' are 'less stringent' than IEC 62443-3-3 since these apply for an SP that is higher than the corresponding SL in IEC 62443-3-3.

4.1.3 Requirement amendments

Any amendment to a requirement summary in these rules means actual requirement text in IEC 62443-3-3 is adapted or customized as described. If no amendment is specified, the requirement summary shall be considered as an interpretation of the referenced requirement in IEC 62443-3-3, hence the referenced standard shall be used to determine the full content, rationale and relevant guidance.

4.1.4 Use of alternative standards

For class notation **Cyber secure** and **Cyber secure(Essential)** systems and components providing navigational and radiocommunication functions may apply IEC 61162-460 in lieu of the required inherent security capabilities in [4.2], [4.3], [4.4], [4.5], [4.7], and [4.8]. Other equivalent standards may be acceptable if found to meet the relevant security profile.

4.2 Identification and authentication

4.2.1 General

This subsection describes requirements for identification and authentication of user prior to accessing the system.

4.2.2 User identification and authentication of human users

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 1.1 Human users shall be identified and authenticated for access to the system.	YES	YES	YES	YES	YES
See IEC-62443-3-3 SR 1.1 RE 1 Human users shall be uniquely identified and authenticated for access to the system.	N/A	N/A	YES	YES	YES
See IEC-62443-3-3 SR 1.1 RE 2 Multifactor authentication is required for human users when accessing the system from or via an untrusted network.	N/A	YES ^H	YES ^H	YES	YES
See IEC-62443-3-3 SR 1.1 RE 3 Multifactor authentication is required for all human users when accessing the system.	N/A	N/A	N/A	N/A	YES

Guidance note:

SR 1.1 and SR 1.1 RE1 do not apply where immediate operator access is needed on board. In such case, identification and authentication should be done by controlling access to the control room (e.g. navigating bridge or central control room). See also applicable requirements in [Pt.4 Ch.9](#).

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

4.2.3 Identification and authentication of software processes and devices

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 1.2 Identification and authentication of devices and software processes shall be implemented on interfaces providing access to the system. Amendments: — For SP0 and SP1, this applies for communication with or via untrusted networks.	YES	YES ^H	YES	YES	YES

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 1.2 RE 1 Unique identification and authentication of devices and software processes is required on interfaces providing access to the system.	N/A	N/A	N/A	YES	YES

4.2.4 Account management

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 1.3 It shall be possible to manage all accounts (human users accounts and non-human user accounts). This shall at least include adding, activating, modifying, disabling, and removing accounts.	N/A	YES	YES	YES	YES
See IEC-62443-3-3 SR 1.3 RE 1 Unified account management is required (either per system or a common solution comprising multiple systems).	N/A	N/A	N/A	N/A ^L	YES

4.2.5 Identifier management

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 1.4 It shall be possible to manage identifiers in the system. The intention is to allow for segregation of duties and least privilege by assignment of different privileges depending on user, role, group or interface.	N/A	YES	YES	YES	YES

4.2.6 Authenticator management

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 1.5 It shall be possible to manage authenticators in the system. This implies e.g. initializing, changing, and protecting passwords from unauthorized disclosure when stored and transmitted. Amendments: — Default passwords shall not be used.	N/A	YES	YES	YES	YES
See IEC-62443-3-3 SR 1.5 RE 1 Authenticators for software processes and device users shall be protected via hardware mechanisms. This applies for e.g. private keys for asymmetric encryption.	N/A	N/A	N/A	N/A ^L	YES

4.2.7 Wireless access management

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 1.6 All users (human and non-human) shall identify and authenticate themselves to access the system by wireless communication.	N/A	YES	YES	YES	YES
See IEC-62443-3-3 SR 1.6 RE 1 Unique identification and authentication is required.	N/A	N/A	YES	YES	YES

4.2.8 Strength of password-based authentication

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 1.7 It shall be possible to configure minimum length of passwords and enforce the use of different character types.	N/A	YES	YES	YES	YES
See IEC-62443-3-3 SR 1.7 RE 1 It shall be possible to configure reuse limitation for human user passwords, in addition to minimum and maximum lifetime of the password.	N/A	N/A	N/A	YES	YES
See IEC-62443-3-3 SR 1.7 RE 2 It shall be possible to configure minimum and maximum lifetime of a password for all user.	N/A	N/A	N/A	N/A	YES

4.2.9 Public key infrastructure (PKI) certificates

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 1.8 If public key infrastructure (PKI) is used, the system shall operate such PKI according to industry best practice.	N/A	N/A	YES	YES	YES

4.2.10 Strength of public key authentication

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 1.9 If public key infrastructure (PKI) is used, requirements for certificate validation and user management in IEC 62443-3-3 SR 1.9 shall be complied with.	N/A	N/A	YES	YES	YES
See IEC-62443-3-3 SR 1.9 RE 1 If public key infrastructure (PKI) is used the system shall protect relevant private keys by hardware mechanisms.	N/A	N/A	N/A	N/A ^L	YES

4.2.11 Authenticator feedback

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 1.10 The system shall obscure feedback during the authentication process (e.g. display asterisks instead of password characters during login process).	N/A	YES	YES	YES	YES

4.2.12 Unsuccessful login attempts

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 1.11 The system shall enforce a limit of consecutive invalid login attempts during a specified time period. Access shall be denied for a configurable period of time or until an administrator unlocks the account. For critical services, the control system shall provide the capability to disallow interactive logons with the service account. Amendments: — For SP1, this applies only for access from or via untrusted networks.	N/A	YES	YES	YES	YES

4.2.13 System use notification

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 1.12 It shall be possible to configure a notification message to be displayed when a human user authenticates to the system. Amendments: — This applies only for access from or via untrusted networks.	N/A	YES	YES	YES	YES

4.2.14 Access via untrusted networks

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 1.13 Any access from or via untrusted networks shall be monitored (e.g. logged, indicated, alarmed) and controlled (e.g. denied, restricted).	YES	YES	YES	YES	YES
See IEC-62443-3-3 SR 1.13 RE 1 The system shall deny access from or via untrusted networks if the request is not approved by authorized personnel on board. Amendments: — See also Pt.4 Ch.9 Sec.4 [3.1.14] .	YES	YES ^H	YES	YES	YES

4.3 Use control

4.3.1 General

This subsection describes requirements for use control.

4.3.2 Authorization enforcement

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 2.1 On all interfaces, human users shall be assigned authorizations in accordance with the principles of segregation of duties and least privilege.	N/A	YES	YES	YES	YES
See IEC-62443-3-3 SR 2.1 RE 1 The enforcement of authorizations applies to all users (human users, software processes and devices).	N/A	N/A	YES	YES	YES
See IEC-62443-3-3 SR 2.1 RE 2 An authorized user shall be able to define and change the assigned authorizations for all human users.	N/A	N/A	YES	YES	YES
See IEC-62443-3-3 SR 2.1 RE 3 It shall be possible for a dedicated role or user to manually override the current user authorizations without needing to close the current session or change view on the HMI. This supervisor override shall be limited in time or limited to the respective operation.	N/A	N/A	N/A	N/A ^L	YES
See IEC-62443-3-3 SR 2.1 RE 4 The system shall require dual approval if the operation may result in critical or hazardous consequences.	N/A	N/A	N/A	N/A	YES

4.3.3 Wireless use control

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 2.2 The system shall authorize, monitor and enforce usage restrictions for wireless connectivity.	N/A	YES	YES	YES	YES
See IEC-62443-3-3 SR 2.2 RE 1 The system shall identify and report unauthorized wireless devices transmitting within the system physical environment.	N/A	N/A	N/A	YES	YES

4.3.4 Use control for portable and mobile devices

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 2.3 The system shall enforce usage restrictions of portable and mobile devices.	YES	YES	YES	YES	YES
See IEC-62443-3-3 SR 2.3 RE 1 The system shall verify that portable and mobile devices connecting to a zone comply with the security requirements of that zone.	N/A	N/A	N/A	YES	YES

4.3.5 Mobile code

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 2.4 The system shall restrict use of mobile code such as java scripts, ActiveX and PDF.	N/A	YES	YES	YES	YES
See IEC-62443-3-3 SR 2.4 RE 1 Prior to executing mobile code, the integrity of the code shall be verified.	N/A	N/A	N/A	YES	YES

4.3.6 Session lock

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 2.5 The system shall be able to prevent further access after a configurable time of inactivity or following activation of manual session lock.	N/A	YES	YES	YES	YES

4.3.7 Remote session termination

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 2.6 The system shall automatically terminate a remote session from/via untrusted networks after a configurable time of inactivity, or by manual termination by a responsible crew member. The effect of terminating a remote session during on-going operations shall be considered and not endanger the vessel or its crew.	N/A	YES ^H	YES	YES	YES

4.3.8 Concurrent session control

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 2.7 The system shall limit the number of concurrent sessions per interface for any user (human, software process or device). The number of sessions shall be configurable.	N/A	N/A	N/A	YES	YES

4.3.9 Auditable events

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 2.8 The system shall generate audit records for access control, request errors, operating system events, control system events, backup and restore events, configuration changes, potential reconnaissance activity and audit log events. Each record shall include timestamp, source, category, type, event ID and event result.	YES	YES	YES	YES	YES
See IEC-62443-3-3 SR 2.8 RE 1 Central management of audit events shall be provided. For a system in SuC, this implies the capability to generate a system-wide time correlated audit trail as well as providing tools to analyse such audit trails. For a vessel, this implies e.g. a SIEM solution that can manage audit records from the systems in the SuC.	N/A	N/A	N/A	YES	YES

4.3.10 Audit storage capacity

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 2.9 Sufficient storage capacity for audits records shall be provided. As part of the audit, storage capacity for such records shall be monitored.	N/A	YES	YES	YES	YES
See IEC-62443-3-3 SR 2.9 RE 1 The system shall issue an alert to responsible personnel before audit record storage capacity is exceeded. The objective is to prevent loss of audit records.	N/A	N/A	N/A	YES	YES

4.3.11 Response to audit processing failures

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 2.10 The system shall alert responsible personnel and prevent loss of essential or important functions in the event of an audit processing failure.	N/A	YES	YES	YES	YES

4.3.12 Timestamp

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 2.11 The system shall timestamp each audit record.	YES	YES ^H	YES	YES	YES
See IEC-62443-3-3 SR 2.11 RE 1 The system shall synchronize internal system clocks at a configurable frequency.	N/A	N/A	N/A	YES	YES

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 2.11 RE 2 The time source shall be protected from unauthorized alteration. If modification has occurred, an audit event shall be recorded.	N/A	N/A	N/A	N/A	YES

4.3.13 Non-repudiation

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 2.12 It shall be possible to determine if a given human user executed a particular action.	N/A	N/A	N/A	YES	YES
See IEC-62443-3-3 SR 2.12 RE 1 It shall be possible to determine if a given user (human, software process or device) executed a particular action.	N/A	N/A	N/A	N/A	YES

4.4 Systems integrity

4.4.1 General

This subsection describes requirements for system integrity.

4.4.2 Communication integrity

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 3.1 The system shall protect the integrity of transmitted information.	N/A	YES	YES	YES	YES
See IEC-62443-3-3 SR 3.1 RE 1 The system shall apply cryptographic algorithms to protect the integrity of transmitted information. Amendments: — For SP0 to SP2, this requirement applies for communication with or via untrusted networks and for wireless networks.	YES	YES ^H	YES ^H	YES	YES

4.4.3 Malicious code protection

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 3.2 The system shall have protection mechanisms against malicious code or unauthorized software. This shall include prevention, detection, reporting and mitigating countermeasures. The protection mechanism shall be kept updated, see also DNV-CG-0325 .	YES	YES	YES	YES	YES
See IEC-62443-3-3 SR 3.2 RE 1 Malicious code protection shall also be implemented on entry and exit points to the system (e.g. removable media, remote access servers, etc.).	N/A	N/A	YES	YES	YES
See IEC-62443-3-3 SR 3.2 RE 2 Central management of malicious code protection mechanisms shall be provided.	N/A	N/A	N/A	YES	YES

4.4.4 Security functionality verification

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 3.3 It shall be possible (at least during test phases and scheduled maintenance) to verify that the required security functions operate as intended.	N/A	YES	YES	YES	YES
See IEC-62443-3-3 SR 3.3 RE 1 The system shall have automatic methods for verification of security functions (at least during test phases and scheduled maintenance).	N/A	N/A	N/A	YES	YES
See IEC-62443-3-3 SR 3.3 RE 2 The system shall provide for verification of security functions during normal operation.	N/A	N/A	N/A	N/A	YES

4.4.5 Software and information integrity

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 3.4 The system shall detect, record, report and protect against unauthorized modification of stored data, e.g. software, configuration parameters and other information. This requirement shall provide additional security in the event that barriers required by FR 1 and FR 2 are circumvented.	N/A	N/A	YES	YES	YES
See IEC-62443-3-3 SR 3.4 RE 1 The system shall alert responsible personnel if the integrity is compromised.	N/A	N/A	N/A	YES	YES

4.4.6 Input validation

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 3.5 Inputs that may directly impact control functions shall be validated. This requirement does not address human error when entering e.g. commands or set-points at a local HMI. Amendments: — For SP1, this requirement applies for inputs originating from or via untrusted networks, e.g. remote access.	N/A	YES	YES	YES	YES

4.4.7 Deterministic output

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 3.6 The system shall respond in a fail-to-safe manner as per Pt.4 Ch.9 Sec.2 [2.2] if normal operation may not be maintained as a result of a cyber incident.	N/A	YES	YES	YES	YES

4.4.8 Error handling

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 3.7 The system shall identify and respond to errors in a manner that supports necessary actions in incident response plans. E.g. avoid disclosing information that can be exploited by adversaries, allow for safe operation by alternative means, effective restoration, support troubleshooting, diagnostics and forensics.	N/A	N/A	YES	YES	YES

4.4.9 Session integrity

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 3.8 The system shall protect the integrity of sessions. Invalid session IDs shall be rejected. Amendments: — For SP0 to SP2, this requirement applies for communication with or via untrusted networks.	YES	YES ^H	YES	YES	YES
See IEC-62443-3-3 SR 3.8 RE 1 The system shall invalidate session IDs upon user logout or other session termination (including browser sessions). Amendments: — For SP1 to SP2, this requirement applies for communication with or via untrusted networks.	N/A	YES ^H	YES ^H	YES	YES
See IEC-62443-3-3 SR 3.8 RE 2 The system shall generate a unique session ID for each session. Unexpected session IDs shall be treated as invalid.	N/A	N/A	N/A	YES	YES
See IEC-62443-3-3 SR 3.8 RE 3 The system shall generate random unique session IDs.	N/A	N/A	N/A	N/A	YES

4.4.10 Protection of audit information

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 3.9 Audit records and tools shall be protected from unauthorized access, modification and deletion.	N/A	N/A	YES	YES	YES
See IEC-62443-3-3 SR 3.9 RE 1 Audit records shall be stored on write-once media.	N/A	N/A	N/A	N/A	YES

4.5 Data confidentiality

4.5.1 General

This subsection describes requirements for data confidentiality.

4.5.2 Information confidentiality

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 4.1 The system shall be able to protect the confidentiality of information at rest or in transit that have read authorization. Amendments: — For SP0, this requirement applies for read-authorized information in transit on untrusted networks.	YES	YES	YES	YES	YES
See IEC-62443-3-3 SR 4.1 RE 1 The system shall be able to protect the confidentiality of information at rest or in transit on untrusted networks. Amendments: — For SP1, this requirement applies for wireless networks.	N/A	YES ^H	YES	YES	YES
See IEC-62443-3-3 SR 4.1 RE 2 The system shall be able to protect the confidentiality of information communicated between different zones.	N/A	N/A	N/A	N/A	YES

4.5.3 Information persistence

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 4.2 The system shall be able to purge information that have read authorisation from components that shall be replaced or decommissioned.	N/A	N/A	YES	YES	YES
See IEC-62443-3-3 SR 4.2 RE 1 The system shall be able to prevent transfer of information stored on volatile shared memory resources (e.g. purge data from RAM before it is made available for a new user).	N/A	N/A	N/A	YES	YES

4.5.4 Use of cryptography

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 4.3 If cryptography is required, the system shall use algorithms, key sizes and mechanisms for key establishment and management based on best practices and recommendations.	YES	YES	YES	YES	YES

4.6 Restricted data flow

4.6.1 General

This subsection describes requirements for security zones and conduits.

The following principles for design of security zones apply:

- 1) systems and components in a security zone shall be protected against unauthorized access and other cyber threats from untrusted networks
- 2) all systems and components in a security zone shall meet the same requirements (i.e., same security profile)
- 3) OT systems and IT systems shall be physically segmented into different zones

- 4) navigational and radiocommunication systems shall be in separate zone(s)
- 5) equipment certified in accordance with IEC 61162-460 or other equivalent standards shall constitute a separate security zone
- 6) systems providing required safety functions shall be physically segmented in separate zone(s)
- 7) wireless devices shall be grouped in zones separated from wired devices
- 8) any facilities for management of portable devices (e.g. 'sheep dip station') shall be grouped into a separate zone.

4.6.2 Network segmentation

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 5.1 Separation of zones in [3.2] shall be implemented by logical or physical network segmentation. Amendments: — Logical network segmentation is generally not accepted for offshore units as per DNV-OS-D202 Ch.2 Sec.3 [3.2.4].	YES	YES	YES	YES	YES
See IEC-62443-3-3 SR 5.1 RE 1 For requirements to physical network segmentation, see [4.6.1].	YES	YES ^H	YES	YES	YES
See IEC-62443-3-3 SR 5.1 RE 2 The system shall be able to provide network services to other OT systems without a connection to non-control system networks.	N/A	N/A	N/A	YES	YES
See IEC-62443-3-3 SR 5.1 RE 3 It shall be possible to isolate critical systems from non-critical networks. Amendments: — Air-gap is generally not required for any system on SP0 to SP3. For SP4, this may be required for systems with critical/safety-related functions on a case-by-case evaluation.	N/A	N/A	N/A	N/A	YES

4.6.3 Zone boundary protection

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 5.2 Communication traversing zone boundaries shall be controlled and monitored to enforce the compartmentalization for zones and conduits.	YES	YES	YES	YES	YES
See IEC-62443-3-3 SR 5.2 RE 1 Communication traversing zone boundaries shall be controlled according to the principle of 'deny by default, allow by exception'.	YES	YES ^H	YES	YES	YES
See IEC-62443-3-3 SR 5.2 RE 2 It shall be possible to manually stop communication between zones serving essential or important services, including boundaries to safety functions and IT zones ('island mode'). Amendments: — Use of data diodes / unidirectional communication may be accepted.	N/A	YES ^H	YES ^H	YES	YES

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 5.2 RE 3 Communication through the zone boundary shall be automatically stopped upon operational failures of the boundary protection. This 'fail close' functionality shall not affect essential services or safety functions.	N/A	N/A	N/A	YES	YES

4.6.4 General purpose person-to-person communication restrictions

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 5.3 External general purpose person-to-person messages shall not be received by the system.	N/A	YES	YES	YES	YES
See IEC-62443-3-3 SR 5.3 RE 1 All general purpose person-to-person communications shall be prohibited.	N/A	N/A	N/A	YES	YES

4.6.5 Application partitioning

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 5.4 Data, applications and services shall be subject to partitioning or separation in accordance with the zoning model. This implies that different zones shall not depend on the same data, applications or services.	N/A	YES	YES	YES	YES

4.7 Timely response to events

4.7.1 General

This subsection describes requirements for timely response to events.

4.7.2 Audit log accessibility

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 6.1 The system shall provide read-only access to audit records for authorized users.	N/A	YES	YES	YES	YES
See IEC-62443-3-3 SR 6.1 RE 1 The system shall provide an application programming interface (API) for access to the audit records.	N/A	N/A	N/A	YES	YES

4.7.3 Continuous monitoring

<i>Requirement summary and amendments</i>	<i>SP0</i>	<i>SP1</i>	<i>SP2</i>	<i>SP3</i>	<i>SP4</i>
See IEC-62443-3-3 SR 6.2 The system shall be able to continuously monitor the performance of security mechanisms. This may be e.g. achieved by use of IDS, IPS, and monitoring of network.	N/A	N/A	YES	YES	YES

4.8 Resource availability

4.8.1 General

This subsection describes requirements for resource availability.

4.8.2 Denial of service protection (DOS)

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 7.1 The system shall be able to operate in a degraded mode during a DOS event. Amendments: — This requirement shall be seen in context with Pt.4 Ch.9 Sec.4 [3.1.3] . — Monitoring and alarming of network status shall follow the requirements in Pt.4 Ch.9 Sec.4 [3.1.4] .	YES	YES	YES	YES	YES
See IEC-62443-3-3 SR 7.1 RE 1 The system shall manage communication loads to mitigate consequences of DOS events, e.g. by use of rate limiting.	N/A	N/A	YES	YES	YES
See IEC-62443-3-3 SR 7.1 RE 2 The system shall be able to prevent or limit the ability of human users, software processes or devices to cause DOS events affecting other systems and networks.	N/A	N/A	N/A	YES	YES

4.8.3 Resource management

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 7.2 The system shall be able to schedule system resources for higher priority software processes such as e.g. shutdowns, alarming and monitoring over lower priority tasks such as e.g. networks scans.	N/A	YES	YES	YES	YES

4.8.4 Control system back-up

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 7.3 It shall be possible to create a complete backup of the system during normal operation.	YES	YES	YES	YES	YES
See IEC-62443-3-3 SR 7.3 RE 1 The system shall be able to verify that the backup is complete and that the data may be used to restore the system.	N/A	N/A	YES	YES	YES
See IEC-62443-3-3 SR 7.3 RE 2 The system shall be able to automatically create a backup of the system during normal operation.	N/A	N/A	N/A	YES	YES

4.8.5 Control system recovery and reconstitution

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 7.4 It shall be possible to recover and reconstitute the system after a cyber incident.	YES	YES	YES	YES	YES

4.8.6 Emergency power

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 7.5 In case the system is supplied from two or more power sources, switching between these sources shall not affect security functions of the system.	N/A	YES	YES	YES	YES

4.8.7 Network and security configuration

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 7.6. It shall be possible to configure the system's network and security parameters according to recommended guidelines from the supplier. An interface shall exist to monitor these settings.	N/A	YES	YES	YES	YES
See IEC-62443-3-3 SR 7.6 RE 1 It shall be possible to create a report in machine-readable format of the network and security parameters.	N/A	N/A	N/A	YES	YES

4.8.8 Least functionality

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 7.7 Unnecessary functions, ports, protocols and/or services shall be disabled, prohibited or removed from the system.	N/A	YES	YES	YES	YES

4.8.9 Control systems components inventory

Requirement summary and amendments	SP0	SP1	SP2	SP3	SP4
See IEC-62443-3-3 SR 7.8 The system shall be able to generate a report of its inventory and associated properties.	N/A	N/A	YES	YES	YES

5 Survey and test

5.1 Introduction

5.1.1 General

After the documents in [1.8.2] have been approved by the Society, manufacturers shall demonstrate compliance with applicable requirements in a manufacturing survey, see [5.2].

After the documents in [1.8.1] have been approved by the Society, the integrator shall demonstrate compliance with applicable requirements on board, see [5.3] and [5.4].

5.1.2 Unauthorized access

Manufacturers and integrator shall ensure that the systems are protected from unauthorized access and tampering during all project phases until the vessel is delivered to the owner.

5.2 Manufacturing survey

5.2.1 General

The system shall as part of the product certification be subject to a manufacturing survey, see [Pt.4 Ch.9 Sec.1 \[1.4\]](#), where required inspections and tests are witnessed by the Society. If product certification is required also by other rules from the Society, there should be one common manufacturing survey covering all applicable requirements.

5.2.2 Prior to testing

The system shall be completed prior to the manufacturing survey.

The manufacturer shall in advance have completed internal testing, including the scope of the approved test programme to ensure that the system is ready for the manufacturing survey. Records from internal testing shall be available to the Society.

Prior to commencing testing of security capabilities, the manufacturer shall demonstrate that the system is correctly represented by the approved documentation, e.g. by checking hardware and software components versus the approved asset inventory.

Temporary user accounts and other interim configuration shall be removed prior to testing.

5.2.3 Testing of security capabilities

The certification test shall be carried out in accordance with the approved test procedure F252 specified in [Table 7](#). The testing shall demonstrate the required security capabilities and correct configuration in accordance with document F141 in [Table 7](#).

If compensating countermeasures are approved in lieu of a required security capability, these countermeasures shall also be tested or demonstrated.

If any required tests cannot be carried out during the certification test, the verification scope may be transferred to onboard testing, subject to acceptance by the integrator. Product certificate will be issued after the applicable requirements have been verified by testing.

5.2.4 Secure development lifecycle

The manufacturer shall present documented evidence that requirements for secure software development lifecycle in [\[3.3\]](#) are adhered to in the organisation.

5.2.5 Document delivery

The manufacturer shall provide the integrator with relevant documentation in [\[1.8.2\]](#) enabling the integrator to:

- design, illustrate and describe the security zones and conduits, see F031 in [Table 6](#)
- implement, integrate and describe the security zones and conduits, see F011 in [Table 6](#)
- compile a complete inventory list for all systems and components in the SuC, see F071 in [Table 6](#)
- describe and carry out testing as per requirements in [\[5.4\]](#), see F251 in [Table 6](#).

The manufacturer shall also provide the integrator with relevant documentation in [\[1.8.2\]](#) supporting development of the owner's cyber security management system.

Guidance note:

To meet the above objectives, the manufacturer will typically need to provide at least the following information to the integrator:

- F030 - System topology
- F071 - Inventory list
- F142 - Information supporting incident response and recovery
- F253 - Procedure for verification of security functions on board.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

5.3 Onboard inspection

5.3.1 General

After the systems have been delivered with product certificate to the vessel, the complete SuC shall be managed during construction and commissioning as per the following paragraphs, subject to inspection by the Society.

5.3.2 Modifications and document management

The integrator shall manage modifications to the SuC in accordance with requirements in [Pt.4 Ch.9 Sec.1 \[1.6\]](#). The documents in [\[1.8\]](#) shall be kept updated during the construction and commissioning phase.

5.3.3 Malware protection

The integrator shall ensure that anti-malware software in the SuC is kept updated, as applicable.

5.3.4 Communication with untrusted networks

The integrator shall ensure that the SuC is not connected to untrusted networks unless all required security countermeasures are implemented.

5.3.5 Mobile and portable devices

The integrator shall ensure that systems are configured with usage restrictions for mobile and portable devices as per [\[4.3.4\]](#) and that any such use is controlled to prevent malware from being introduced in the SuC.

5.3.6 Document delivery

The integrator shall provide the shipowner with the following documents upon delivery of the vessel:

- F011 - Cyber security design description, see [\[1.8.1\]](#)
- F031 - Zone and conduit diagram, see [\[1.8.1\]](#)
- F071 - Complete vessel asset inventory, see [\[1.8.1\]](#)
- F251 - Test procedure as per requirements in [\[5.4\]](#), see [\[1.8.1\]](#)
- Relevant system documentation in [\[1.8.2\]](#) as specified in [\[5.2.5\]](#).

5.4 Onboard testing

5.4.1 General

At the end of the commissioning phase, testing shall be carried out to demonstrate that the complete and integrated SuC meets applicable security requirements.

Test procedure F251 in [Table 6](#) shall be approved before commencing the onboard testing and include at least the tests in this subsection. The tests shall be witnessed by the Society.

5.4.2 System security functions

Testing of security capabilities is generally not required to be repeated on board in commissioning phase since the systems and components in the SuC shall be delivered with compliance documents as per [\[1.8.3\]](#).

Any findings, comments, conditions or approved compensating countermeasures identified in product certification or type approval shall nevertheless be subject to testing on board.

5.4.3 Vessel asset inventory

It shall be demonstrated that systems and components in the SuC are correctly represented by the vessel asset inventory and that security updates have been implemented, see [1.8.1] and [3.3].

5.4.4 Malicious code protection

Countermeasures protecting the systems from malware and unauthorised software shall be demonstrated, see [4.4.3].

Guidance note:

This test may be omitted in the commissioning phase if fully covered by product certification or type approval.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

5.4.5 Hardening and configuration

It shall be demonstrated that hardening and configuration of security capabilities have been completed in accordance with applicable requirements, see [4.8.7], [4.8.8], and [3.3].

Guidance note:

This test may be omitted in the commissioning phase if fully covered by product certification or type approval.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

5.4.6 Physical access control

It shall be demonstrated that components in the SuC are located in areas or enclosures where physical access can be controlled to authorised personnel, see [5.1.2].

5.4.7 Logical access control

It shall be demonstrated that user accounts are configured according to the principles of segregation of duties and least privilege, and that temporary accounts have been removed, see [4.2.2] and [4.3.2].

Guidance note:

This test may be omitted in the commissioning phase if fully covered by product certification or type approval.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

5.4.8 Network segmentation

Network segmentation of security zones shall be tested, and it shall be demonstrated that systems and components in the security zones correspond with the approved zones and conduit diagram, see [4.6.2].

5.4.9 Zone boundary control

Security zone boundaries shall be tested. It shall be demonstrated that only traffic that has been documented in the approved cyber security design description can traverse a security zone boundary, see [4.6.3].

It shall be demonstrated that general purpose person-to-person communication is restricted, see [4.6.4].

5.4.10 Application partitioning

Application partitioning shall be tested by demonstrating that systems in a security zone do not depend on data, applications or services in other zones or networks, see [4.6.5].

5.4.11 Denial of service

Denial of service attacks targeting zone boundary protection devices shall be tested, see [4.8.2].

Denial of service events for each system in the SuC shall be tested as listed below, see [4.8.2] and [4.4.7].

- flooding of network (i.e. attempt to consume the available capacity on the network segment)
- application layer attack (i.e. attempt to consume the processing capacity of selected endpoints in the network).

Guidance note:

Testing of DoS-events for systems may be omitted in the commissioning phase if fully covered by product certification or type approval.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

5.4.12 Communication with untrusted networks

Communication with/via untrusted networks shall be tested. See requirements listed below:

- SR 1.1 RE2: multifactor authentication
- SR 1.2: identification and authentication of endpoints
- SR 1.11: unsuccessful login attempts
- SR 1.12: system use notification
- SR 1.13: access via untrusted networks
- SR 1.13 RE1: explicit access approval
- SR 2.6: remote session termination
- SR 2.8: remote sessions are logged as security events
- SR 3.1 RE1: cryptographic integrity protection
- SR 3.5: input validation
- SR 3.8 (incl. RE's): session integrity

5.4.13 Wireless networks

It shall be tested that only authorized devices can access wireless networks as per [4.2.7], and that secure communication is used in accordance with [4.3.3], [4.4.2], and [4.5.2].

Guidance note:

This test may be omitted in the commissioning phase if fully covered by product certification or type approval.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

5.4.14 Mobile and portable devices

Means to control use of mobile and portable devices shall be demonstrated, see [4.3.4].

5.4.15 Monitoring and diagnostics functions

Monitoring and diagnostics functions shall be tested. See requirements listed belows.

- activation of alarm upon disconnection of network connections, see Pt.4 Ch.9 Sec.2 [2.1.2]
- activation of alarm upon high network traffic load, see Pt.4 Ch.9 Sec.4 [3.1.4]
- generation of audit records, see [4.3.9], [4.3.10], [4.3.11], and [4.7.2]
- intrusion detection systems, if applicable.

Guidance note:

This test may be omitted in the commissioning phase if fully covered by product certification or type approval.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

5.4.16 Verification of security functions

The effectiveness of document F253 shall be demonstrated, see [4.4.4] and [1.8.2].

Guidance note:

This test may be omitted in the commissioning phase if fully covered by product certification or type approval.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

5.4.17 Incident response and recovery

It shall be demonstrated that security zones and local control systems can be isolated and operate independently, see [4.6.3].

Product user manuals or procedures for backup, restore, shutdown, reset, roll-back, and/or restart shall be demonstrated, see [4.8.4], [4.8.5].

Guidance note:

These tests may be omitted in the commissioning phase if fully covered by product certification or type approval.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

5.4.18 Systems excluded based on negligible risk

It shall be demonstrated that systems approved to be excluded from the SuC meet the acceptance criteria in [2.2].